

Oops! Modern Management Mistakes to Avoid



Speakers



Tim De Keukelaere



Modern Workplace
Architect



Endpoint Lead
@ The Collective



Microsoft MVP
Security



Tim.De.Keukelaere@it-essence.be



<https://linktr.ee/timdk>



Peter Daalmans

Modern Workplace Architect, MVP, MCT



peter@secminds.nl

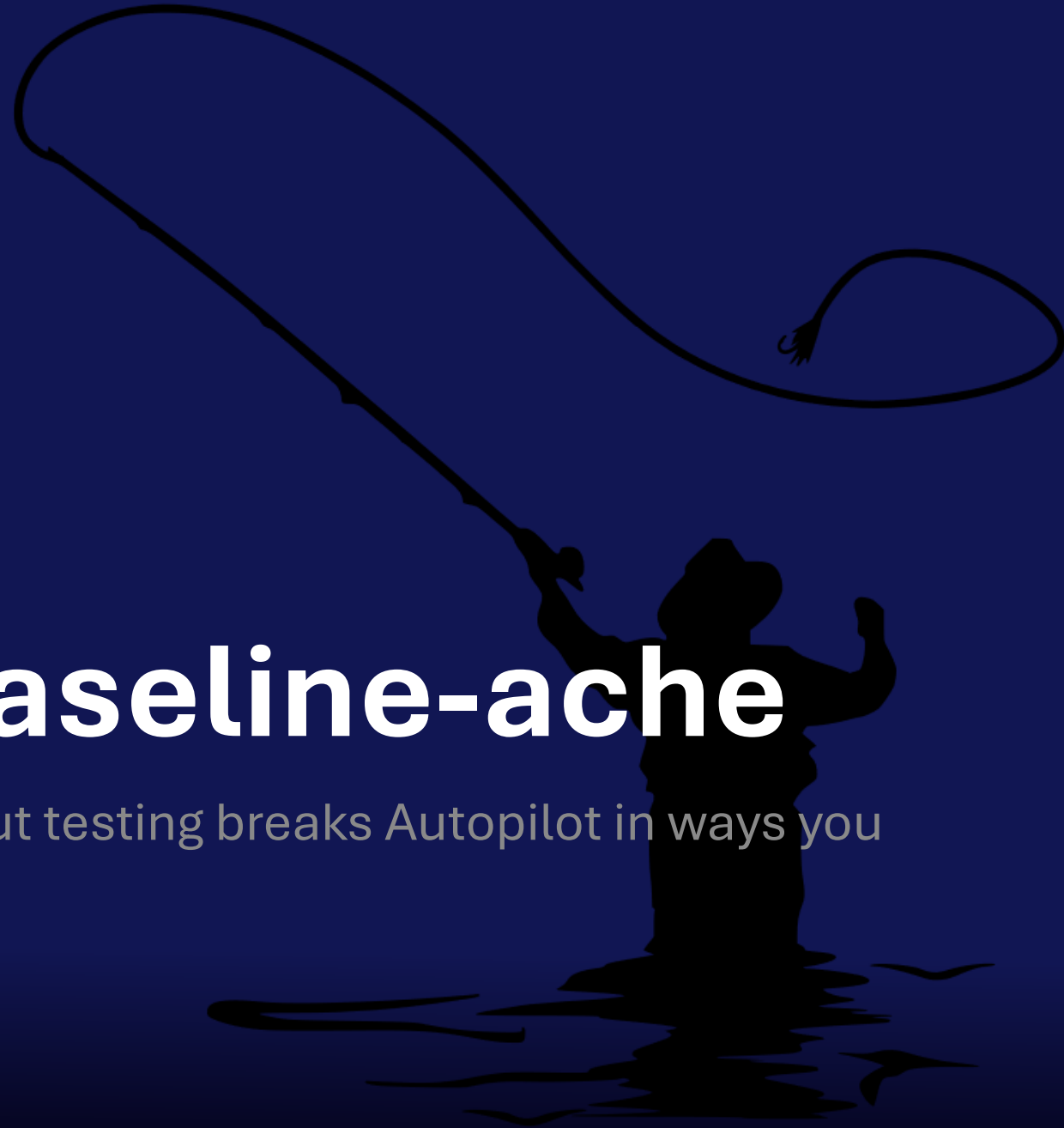


<https://ref.ms/pdaalmans>

Can't see our slides? Can't hear? Need to repeat the question? Call us out!

CLS Baseline? More like CLS Baseline-ache

Deploying hardening benchmarks without testing breaks Autopilot in ways you won't see coming.



Deploying CIS Benchmarks / Windows Baselines Without Testing First

⚠ The Trap

- Hundreds of settings — applying as a block without testing will break things
- Level 1 = broad applicability
- Level 2 = high-security only — applied in standard enterprise causes self-inflicted outages

💥 Real-World Pain

- ✗ CIS reboot + WU settings interfere with Autopilot OOB — devices loop or fail silently
- ✗ No clear error in the Intune portal
- ✗ Settings that disable services Intune depends on — breaks MDM check-ins post-deployment

✓ Do It Right

- ✓ Pilot on a dedicated test group first
- ✓ Compare benchmark settings against existing Intune policies — identify conflicts before broad deployment
- ✓ Use Microsoft Security Compliance Toolkit — document every deviation with business justification

💡 CIS is a starting point, not a drop-in solution — every deviation needs a business reason and audit evidence.

Disabling Firewall Rule Merging Breaks Everything



How It Works

- Two rule sources: local (device) + policy (MDM/GPO) — merged and applied by default
- MergePolicy controls whether local rules are combined with or ignored by policy rules

✗ The Mistake

- ✗ MergePolicy=0 silently blocks apps, agents and services that register their own firewall exceptions
- ✗ EDR, VPN, print spoolers, backup clients — install fine but stop communicating
- ✗ Failure is hard to trace back to the firewall policy

✓ Do It Right

- ✓ Only set MergePolicy=0 if every required rule is explicitly in your Intune/GPO policy
- ✓ If any app uses local rules — keep merging enabled or replicate the rule into managed policy
- ✓ Test on a pilot group first — enable FW logging to catch blocked traffic before user impact

💡 Use `netsh advfirewall set allprofiles logging droppedconnections enable` to catch blocked traffic before it becomes an outage.

Baseline Resources

Official Microsoft

- **Intune Security Baselines**
aka.ms/IntuneSecurityBaselines
Built-in to Intune: Windows, Defender for Endpoint, Edge, M365 Apps
- **Security Compliance Toolkit (SCT)**
aka.ms/SCT
GPO baselines + Policy Analyzer tool for Windows 11 & Server
- **Microsoft Security Baselines**
aka.ms/securitybaselines
Release announcements for every new baseline version

Community & Open Source

- **OpenIntuneBaseline (OIB)**
openintunebaseline.com
Community-driven, importable via IntuneManagement tool. Windows, macOS, iOS. By James Robinson (MVP).
- **IntuneBaselines (Jan Mulder)**
github.com/IntuneAdmin/IntuneBaselines
739+ profiles incl. CIS Edge, Zero Trust, best-practice JSON exports
- **IntuneManagement Tool (Mikael Karlsson)**
github.com/Micke-K/IntuneManagement
Bulk import/export tool used by most community baselines

Frameworks & Benchmarks

- **CIS Intune Benchmark**
cisecurity.org/benchmark/intune
L1/L2 Windows, Edge, and M365 benchmarks mapped to Intune CSPs
- **DISA STIGs for Intune**
public.cyber.mil/stigs
US DoD hardening guidance — highest strictness, requires tuning for enterprise
- **NIST SP 800-124 Rev. 2**
csrc.nist.gov/publications/detail/sp/800-124/rev-2/final
NIST guidelines for managing and securing mobile devices in enterprise

 No baseline is a drop-in solution — treat them as a starting point and tune to your environment before deploying to production.

Unexpected reboots

Registry keys that affect Windows Autopilot if a device setting requires a reboot during device ESP

Registry key:

If the [AutoAdminLogon](#) registry key is set to 0 (disabled), this breaks Windows Autopilot.

Registry path:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows  
NT\CurrentVersion\Winlogon\Automatic logon
```

Windows Security
Baseline/Administrator elevation
prompt behavior

Windows Security Baseline/Require
admin approval mode for
administrators

Windows Security Baseline / Enable
virtualization based security

These policies require a reboot, as a result more prompts might appear when modifying user account control (UAC) settings during the OOBЕ using the device Enrollment Status Page (ESP). Increased prompts are more likely if the device reboots after policies are applied. To work around this issue, the policies can be targeted to users instead of devices so that they apply later in the process.

AppLocker CSP

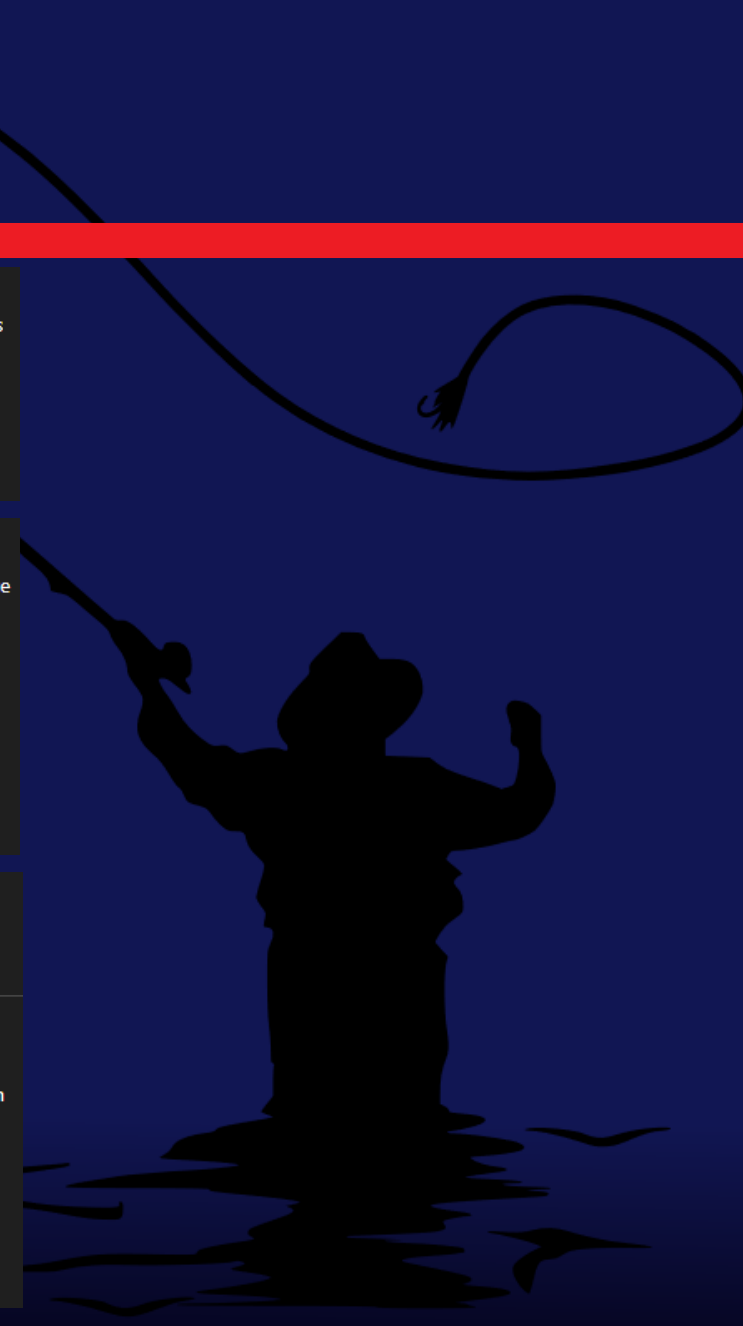
The AppLocker configuration service provider (CSP) isn't supported in the Enrollment Status Page as it triggers a **reboot** when a policy is applied or a deletion occurs.

Device restriction/Password Policy

The out-of-box experience (OOBE) or user desktop autologon can fail when a device **reboots** during the device Enrollment Status Page (ESP). This failure can occur when certain [DeviceLock policies](#) are applied to a device. Such policies can include:

- Minimum password length and password complexity
- Any similar group policy settings (including any that disable autologon)

This possible failure is especially true for kiosk scenarios where passwords are automatically generated.



It's not always DNS ...

... it could be the notwork*



Why can't my endpoint reach the cloud?

⚠ The Trap

- Endpoints can reach Microsoft cloud services through the existing corporate proxy
- TLS inspection and PAC files are harmless for managed traffic
- Generic firewall rules cover what Intune, Defender and Windows Update need

💥 Real-World Pain

- ✗ TLS inspection breaks certificate pinning — silent enrollment failures
- ✗ A single missing FQDN out of 200+ kills check-ins with no clear portal error
- ✗ Internal DNS or PAC bypass causes intermittent, hard-to-diagnose drops

✓ Do It Right

- ✓ Bypass *.manage.microsoft.com and required URLs from SSL inspection
- ✓ Validate the full Microsoft endpoint allow-list against Intune docs
- ✓ Test connectivity with Test-NetConnection and / or the Intune connectivity tool before rollout

💡 ~30% of Intune issues trace back to network connectivity — validate the path before you blame the policy.

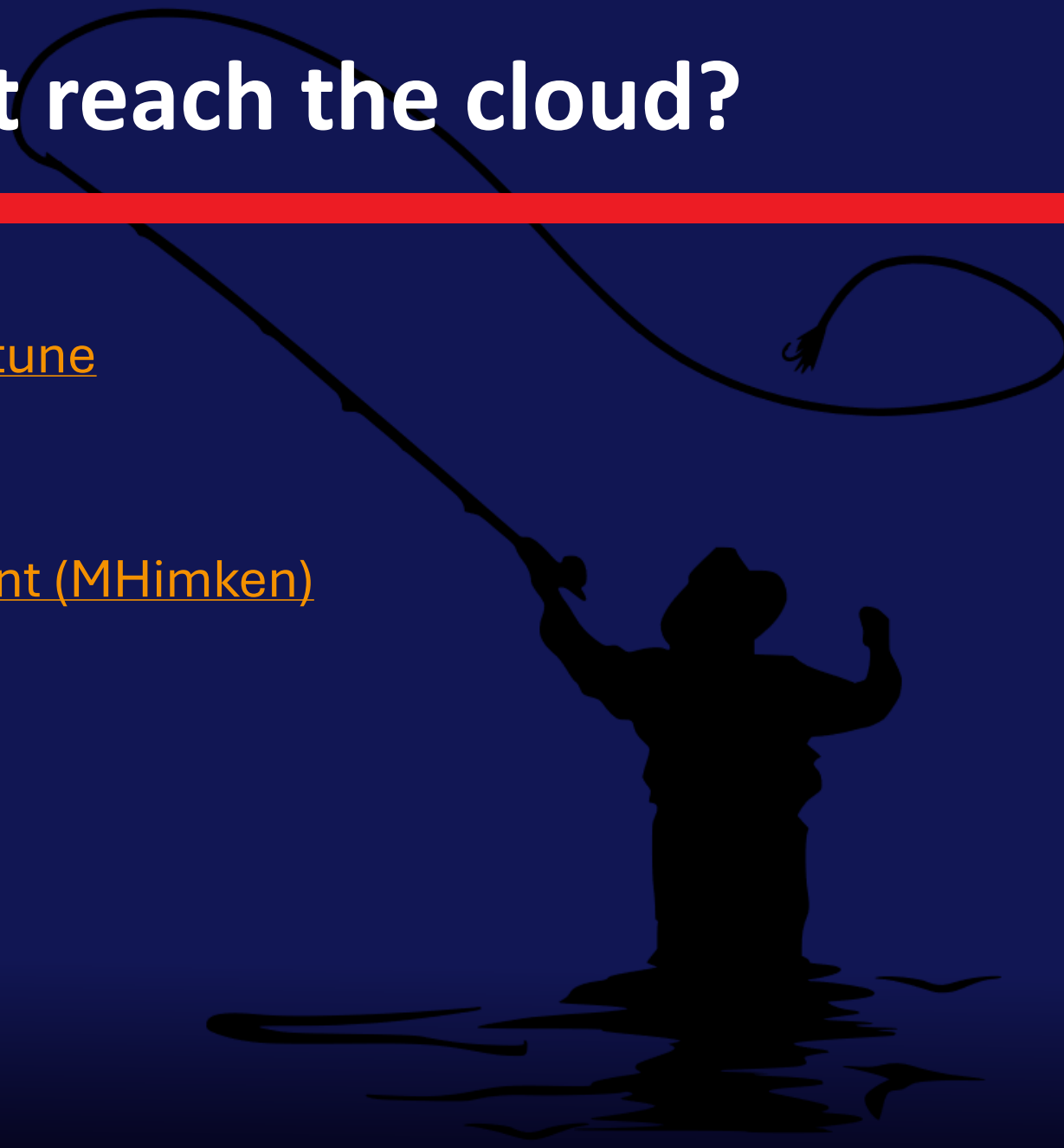
Why can't my Endpoint reach the cloud?

- ◆ References:

- ◆ [Network endpoints for Microsoft Intune](#)

- ◆ Tools

- ◆ [GitHub - IntuneNetworkRequirement \(MHimken\)](#)



Stop Hard-Coding Your Firewall Rules

Use Microsoft's Dynamic Endpoint Web Service



What is it?

Microsoft publishes a **REST web service** that returns the current, authoritative list of all Microsoft 365 and cloud service endpoints — IP ranges and URLs — in machine-readable format.

Formats available:

[JSON](#) · [CSV](#) · [RSS feed](#)

Instances:

[Worldwide](#) · [GCC](#) · [DoD](#) · [GCC High](#) · [China](#)

Updated monthly, with 30 days advance notice before a new endpoint goes live — giving you a change window before connectivity breaks.



3 ENDPOINT CATEGORIES

OPTIMIZE

Tiny set (~10 FQDNs). Highest latency sensitivity. Must bypass proxy and SSL inspection. Direct internet path required. Examples: *.teams.microsoft.com, *.sharepoint.com

ALLOW

Larger set. Important Microsoft services. Should bypass SSL inspection. Can go via proxy. Examples: *.office.com, *.office365.com, login.microsoftonline.com

DEFAULT

All remaining Microsoft traffic. Can be proxied and inspected normally. Lowest priority but still must be reachable — blocking causes silent feature failures.



AUTOMATE IT



RSS Feed → Power Automate

Subscribe to the RSS feed in Power Automate. Trigger a flow on change, send email to your firewall team, optionally push rules automatically.



PowerShell / Python Polling

Poll endpoints.office.com/changes/Worldwide/{version} on a schedule. Compare against your current version file. Diff new IPs/URLs and push to firewall API.



Native Firewall Vendor Integration

Palo Alto, Fortinet, Cisco, Check Point and many others have built-in connectors that consume the JSON feed and update rules automatically — no scripting needed.



30-Day Change Window

New endpoints are published 30 days before going live — giving you a full month to test and deploy rule updates before a missed entry breaks connectivity.

Web service: endpoints.office.com/endpoints/worldwide **Changes feed:** endpoints.office.com/changes/worldwide/{version} **Docs:** aka.ms/o365ip

DEMO

Intune Network Requirements Tool

By Martin Himken

<https://github.com/MHimken>





Administrator: PowerShell 7 (x64)

```
PS C:\Admin\Tools\IntuneNetworkRequirements> cls
```



15°C
Zware regen



Search



ENG



15:31
18/04/2026





```
Administrator: PowerShell 7 (x64)
PS C:\Admin\Tools\IntuneNetworkRequirements>
```



Search



ENG

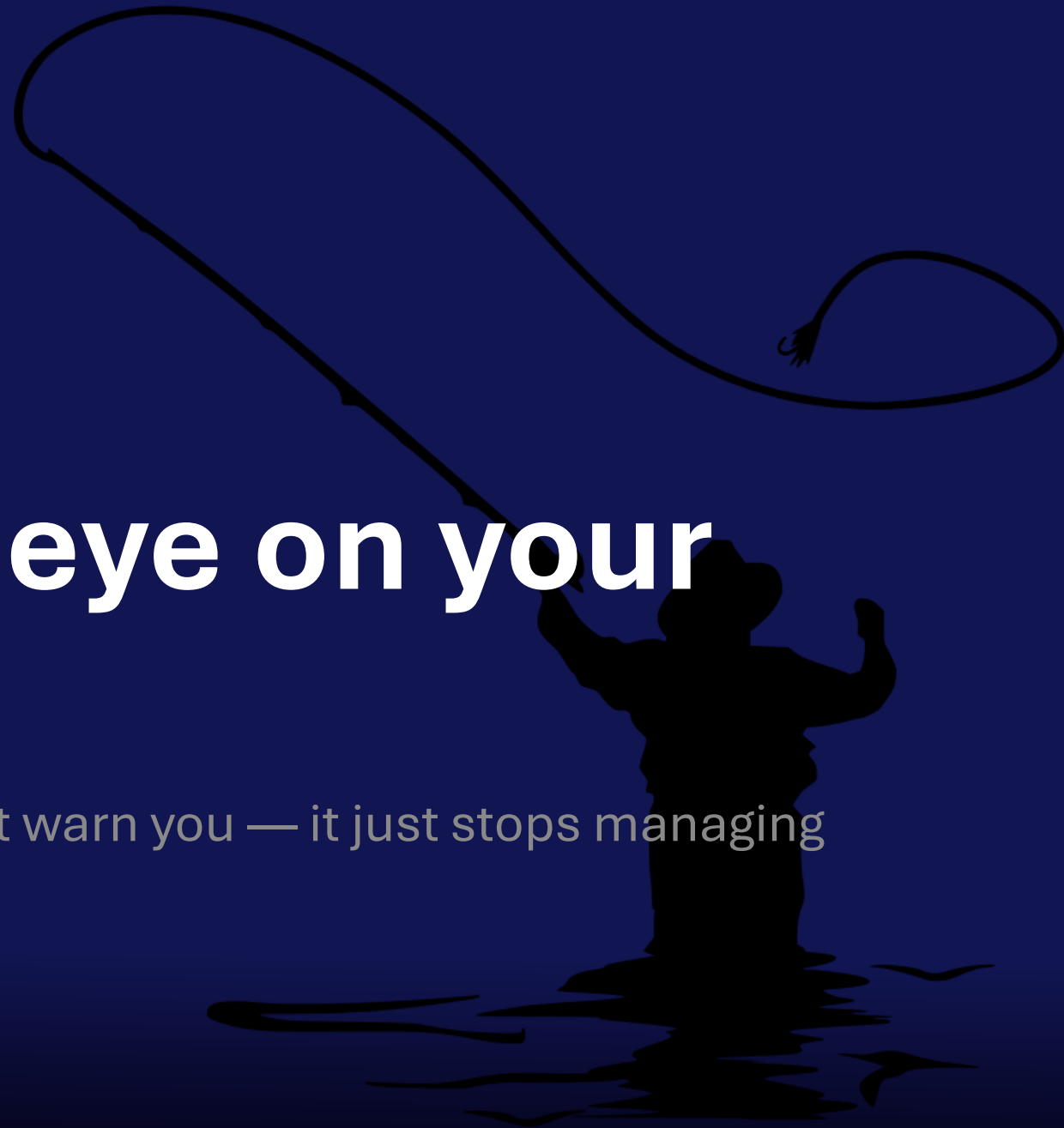


20:25
18/04/2026



Not keeping an eye on your Apple Certs

An expired MDM Push Certificate doesn't warn you — it just stops managing your Macs.



Keep an eye on your Apple certs



How It Works

- MDM Push Cert — connects devices to Intune (yearly expiry, 30-day grace)
- Enrollment Token — used by ABM/ASM to enroll new devices
- VPP Cert — deploys purchased apps to managed devices

✗ The Mistake

- ✗ MDM Push expires — every Mac drops out of Intune; only fix is wipe + re-enroll
- ✗ Enrollment Token expires — new devices can't enroll into ABM/ASM
- ✗ VPP expires — users silently can't install any new apps
- ✗ No clear alert in Intune — you find out from tickets, not the portal

✓ Do It Right

- ✓ Calendar reminders 60 days before each cert expires
- ✓ Document the renewal owner and Apple ID used for each cert
- ✓ Check Apple cert status first when troubleshooting Mac enrollment or app issues
- ✓ Renew MDM Push using the same Apple ID — a new ID forces wipe + re-enroll

💡 Apple certs are silent killers — the portal won't warn you, the helpdesk will.

Push Notification Certificates

Configure MDM Push Certificate

 Delete

^ Essentials

Status

 Expiring

Last updated

4/16/2026

Apple ID

peter@daalmansconsulting.com

Serial number

Days until expiration

30

Expiration

5/17/2026

Subject ID

com.apple.mgmt.External.f26cbc29-99b3-4402-a542-e6bf16...

Accept the Terms and Conditions!

Intune DC Prod ...
Enrollment program tokens

Search x << Delete Renew token Set default profile

Overview

Manage

- Devices
- Profiles

Essentials

Status	Apple ID
⚠ Expiring. Renew in the Apple Portal	peter@daalmansconsulting.com
Expiration Date	Program Type
5/17/2026	Apple Business Manager
Days Until Expiration	Default iOS/iPadOS Enrollment Profile
30	No default set
Last Sync Status	Default macOS Enrollment Profile
Terms and Conditions not accepted	No default set

Essentials

Status

✓ [Active](#)

Expiration Date

4/17/2027

Days Until Expiration

364

Last Sync Status

Success

VPP

 Connectors and tokens | Apple VPP Tokens

[+ Create](#) [Refresh](#)

Windows

Windows enterprise certificate

Microsoft Endpoint Configuration Manager

Windows data

Apple

Apple ID ↑	Token name	Status	Organization name	Token location	Account type	Last sync time	Expiration date	Last updated
peter@daalmansconsulting	DaalmansCons...	✓ Active	Daalmans Consulting	Daalmans Consulting	Business	4/17/2026, 5:35 AM	5/17/2026	4/17/2026

 DaalmansConsulting | Properties

Manage

Properties

Essentials

State : valid

Expiration date : 4/17/2027

Don't overload your ESP

... time to put it on a diet?



Don't overload your Enrollment Status Page



How It Works

- ESP blocks the desktop until tracked apps and policies install
- Two phases: Device Setup (system) and Account Setup (user)
- Default timeout: 60 minutes — hit it and the device is left in a broken state
- Every tracked app = more time the user stares at a progress bar

✗ The Mistake

- ✗ Mixing Win32 + Store + LOB apps — different engines cause race conditions and timeouts
- ✗ Tracking non-critical apps (productivity suites, departmental tools) in ESP
- ✗ Too many tracked apps — each one increases timeout risk
- ✗ Treating ESP as a software depot instead of an entryway

✓ Do It Right

- ✓ Track only the minimum baseline apps required on first login
- ✓ Stick to one app type where possible — prefer Win32 (Intune Management Extension)
- ✓ Defer everything else to Company Portal / required-install after sign-in
- ✓ Tune the timeout based on real test runs — don't leave it at the default

💡 ESP is the front door, not the warehouse — the fewer apps it tracks, the faster every user gets to their desktop.

ESP Best Practices



ADD TO ESP TRACKING



Security agents only

EDR/AV (Defender for Endpoint / Sentinel One), DLP agents, encryption (BitLocker CSP). These are mandatory-before-use and install reliably as Win32.



Single app type per profile

Use Win32 apps exclusively in ESP tracking profiles. Never mix Win32, Store (WinGet), and LOB (.intunewin) in the same tracked assignment.



Dependency-free, fast installers

Apps that install silently in under 5 minutes with no reboots mid-install. Test install time on a clean VM before adding to ESP.



VPN client (if required for policy)

Only if policies cannot apply without it. Use the tunnel app or a lightweight SSTP client — not a full suite with dependencies.



KEEP OUT OF ESP TRACKING



Office / M365 Apps suite

Office installs are large, slow, and have multiple restart cycles. Push via a separate post-ESP policy or use Microsoft 365 Apps assignment outside tracking.



Store / WinGet / LOB mixed in

Mixing app types creates tracking conflicts. The Intune Management Extension handles Win32; different engines handle Store/LOB. Don't combine them in one ESP profile.



Line-of-business / dept. apps

CRM, ERP, Adobe, departmental tools — deliver these post-ESP via a separate required assignment. They don't affect device security posture at enrollment time.



Anything with long install time

If an app takes 10+ minutes or requires multiple reboots, it does not belong in ESP. It will hit the 60-minute timeout and leave devices stranded.

Golden Rule: If it's not required for the device to be secure and compliant before first login, it does not belong in ESP tracking. **Deliver everything else post-enrollment.**

Still using local Admins?



Stop Giving Users Local Administrator Rights



How It Works

- Local admin rights let a user (or any process running as that user) install software, modify system files, disable security tools, and make registry changes with no UAC block
- Malware inherits the rights of the user that launched it — on a local admin account that means SYSTEM-level access from a single click
- ISO 27001, CIS Controls, and NIST all require least-privilege — blanket local admin is an automatic audit finding

✗ The Mistake

- ✗ "The app needs it" — legacy apps demanding admin rights, so the whole account gets elevated permanently
- ✗ "IT is too slow" — helpdesk granted it once to close a ticket and nobody ever revoked it
- ✗ "Power users need it" — devs, finance, and execs all get blanket admin "just in case"
- ✗ No process to revoke — local admin accumulates over time with no regular audit or expiry

✓ Do It Right

- ✓ Remove all standing local admin rights — run everyone as a standard user
- ✓ Use Intune EPM to elevate specific apps or tasks per-policy — the user never becomes an admin
- ✓ Deploy Windows LAPS to rotate the built-in local Administrator account — IT break-glass only, not for daily use
- ✓ Audit the local Administrators group monthly — any account that isn't LAPS or a service account should be removed
- ✓ Devs local admin? Then no access to production systems/data.



Local admin is not a convenience feature, it is a security boundary.

Endpoint Privilege Management: Elevate the Task. Not the User.

01



Define Elevation Rules

In Intune, create EPM policies that specify exactly which applications or tasks are allowed to run elevated — by file hash, certificate, or path. No blanket permissions.

02



User Requests Elevation

When a standard user needs to run an elevated task, they right-click and select 'Run with elevated access'. A support-approved request flow can be triggered automatically or on-demand.

03



Full Audit Trail

Every elevation is logged in Intune — who elevated, which app, which device, at what time. Security teams get complete visibility with no impact on the user workflow.



Standard Users — Always

Remove all permanent local admin rights. EPM works exclusively with standard user accounts — no admin group membership required or desired.



Managed Elevations Only

Elevation is granted per-app, not per-user. The user never becomes an admin — only that specific process runs elevated in a sandboxed context.



Works Alongside LAPS

LAPS manages the local Administrator account for IT break-glass access. EPM handles day-to-day user elevation needs. They are complementary, not competing.



Support Approvals for Edge Cases

For apps not pre-approved, users can submit a support-approved request. Helpdesk can grant a time-limited, single-use elevation token — no permanent rights ever granted.

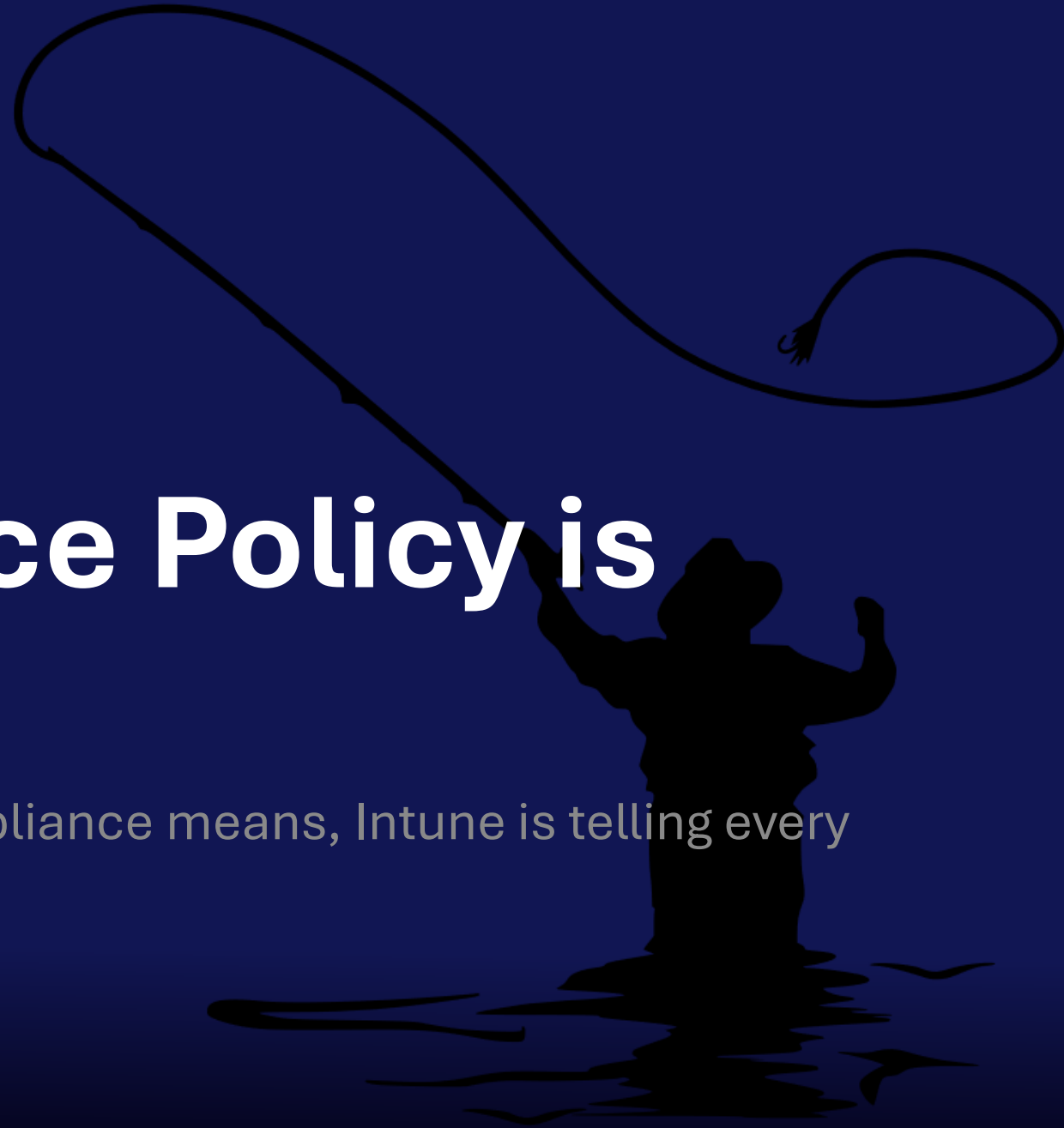
DEMO

EPM



Your Compliance Policy is Lying to You

If you haven't configured what non-compliance means, Intune is telling every device it's doing great.



Having a half-baked compliance setup



How It Works

- Compliance policies evaluate device posture (encryption, OS version, password, etc.)
- Result feeds Conditional Access — the gate that actually blocks access
- Devices with no policy assigned default to Compliant
- Grace periods give users time to remediate before non-compliance bites

✗ The Mistake

- ✗ Leaving “mark devices with no policy as Compliant” — unmanaged devices look fine
- ✗ Compliance without Conditional Access — it’s just a report, not enforcement
- ✗ Hard-coded minimum OS versions that go stale (e.g. Win11 22H2 still listed as compliant)
- ✗ Indefinite grace periods that hide non-compliance forever

✓ Do It Right

- ✓ Flip the default: Compliance settings → mark untargeted devices as Non-compliant
- ✓ Pair with a CA policy: Require compliant device, target All Cloud Apps, start in Report-Only
- ✓ Review minimum OS versions quarterly against the Windows lifecycle
- ✓ Use grace periods deliberately (e.g. 3 days for patching) — never indefinite

💡 Compliance is a posture check; Conditional Access is the door. You need both, and they need to be reviewed on a cadence.

Don't Go Hybrid If You Can Go Home

Hybrid Azure AD Join via Autopilot adds on-prem complexity to a cloud-first workflow — and it shows.



Don't Go Hybrid Join via Autopilot

⚠ Hybrid Join (HAADJ)

- ✗ DC must be reachable during OOB
- ✗ VPN or line-of-sight required at enrollment
- ✗ Enrollment stalls silently if DC unreachable
- ✗ 30–60 min policy sync via Entra Connect
- ✗ GPO + Intune policy conflicts are common

✓ Entra ID Join (Cloud-only)

- ✓ No DC dependency – enrolls from anywhere
- ✓ No VPN needed at enrollment time
- ✓ Ships directly to end-users out of the box
- ✓ Full Intune management from day one
- ✓ No policy sync delay or GPO conflicts

💡 Still need on-prem resources? Deploy Entra Private Access or a VPN client post-enrollment — not Hybrid Join.

Entra ID join

- ♦ <https://learn.microsoft.com/en-us/autopilot/windows-autopilot-hybrid?tabs=general-requirements%2Cupdated-connector%2Cwindows-server-2025>

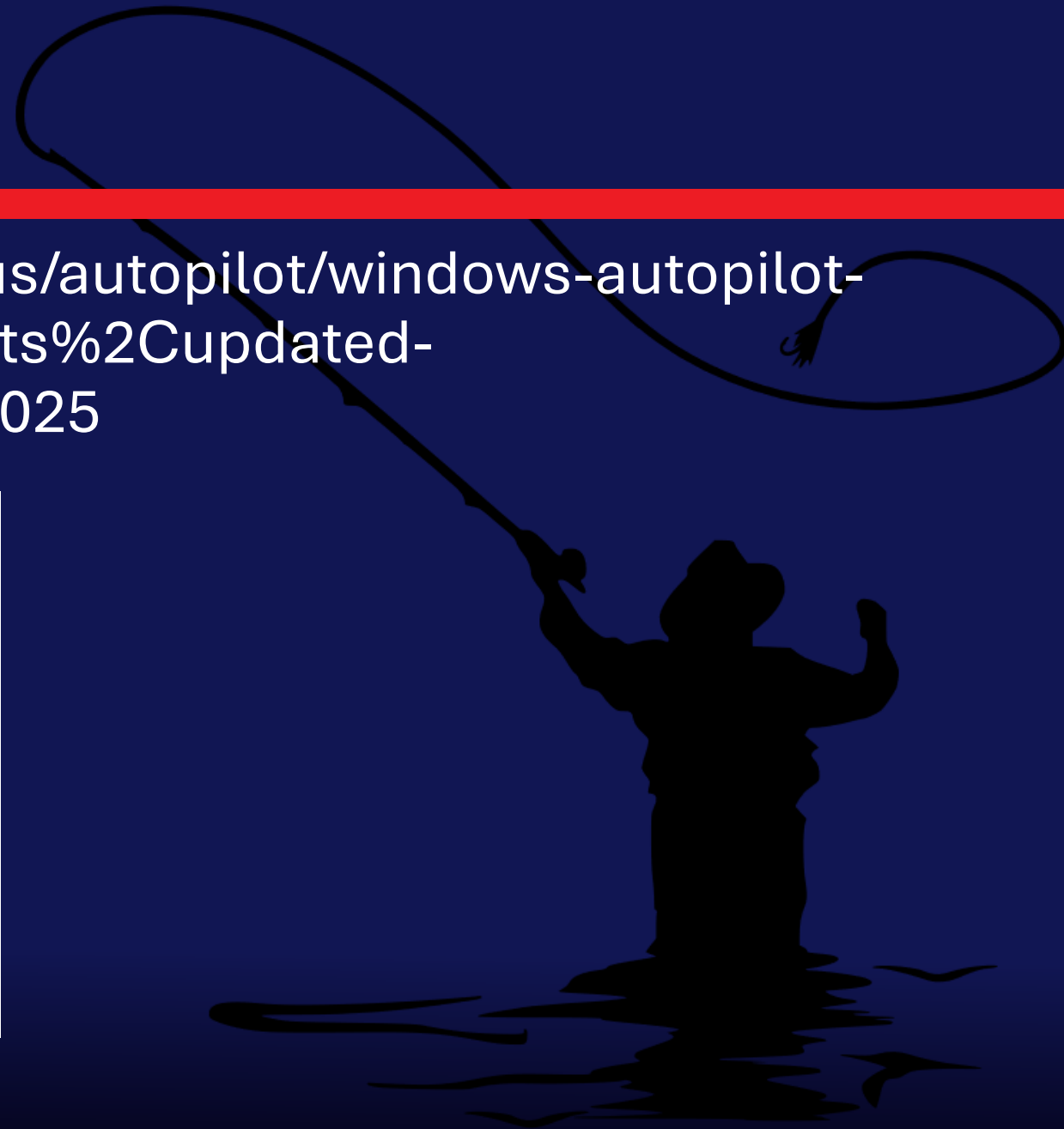
Deploy Microsoft Entra hybrid joined devices by using Intune and Windows Autopilot

Applies to: ☒ Windows 11, ☒ Windows 10, ☒ Windows Server 2025, ☒ Windows Server 2022, ☒ Windows Server 2019, ☒ Windows Server 2016

 Summarize this article for me

Important

Microsoft recommends deploying new devices as cloud-native using Microsoft Entra join. Deploying new devices as Microsoft Entra hybrid join devices isn't recommended, including through Windows Autopilot. For more information, see [Microsoft Entra joined vs. Microsoft Entra hybrid joined in cloud-native endpoints: Which option is right for your organization.](#)



Confusing though..



- ◆ The following use cases are enabled for preview:
 - ◆ Deploy non-persistent Virtual Desktop Infrastructure (VDI) with Microsoft Entra hybrid join in a managed environment.
 - ◆ Deploy Microsoft Entra hybrid join for customers who have or want to use Microsoft Entra Cloud Sync.
 - ◆ Improve provisioning experience for Azure Virtual Desktop and Windows 365 hybrid deployment.
 - ◆ Deploy Microsoft Entra hybrid join for a disconnected forest setup where Microsoft Entra Connect Sync can't be used.

A silhouette of a person standing in water, casting a lasso. The lasso is in mid-air, forming a large loop. The person is wearing a hat and a long-sleeved shirt. The background is a solid dark blue.

Co-Management: Don't Pull the Lever Too Soon

Moving workloads to Intune before your policies are ready leaves devices in a management vacuum.

Co-Management Workloads



How It Works

- Co-management shares authority between ConfigMgr and Intune per workload
- Moving a workload to Intune instantly removes ConfigMgr control over it
- Workloads include: Compliance, Client Apps, Device Config, Endpoint Protection, and more
- The slider is irreversible in effect — Intune must be ready before you move it

✗ The Mistake

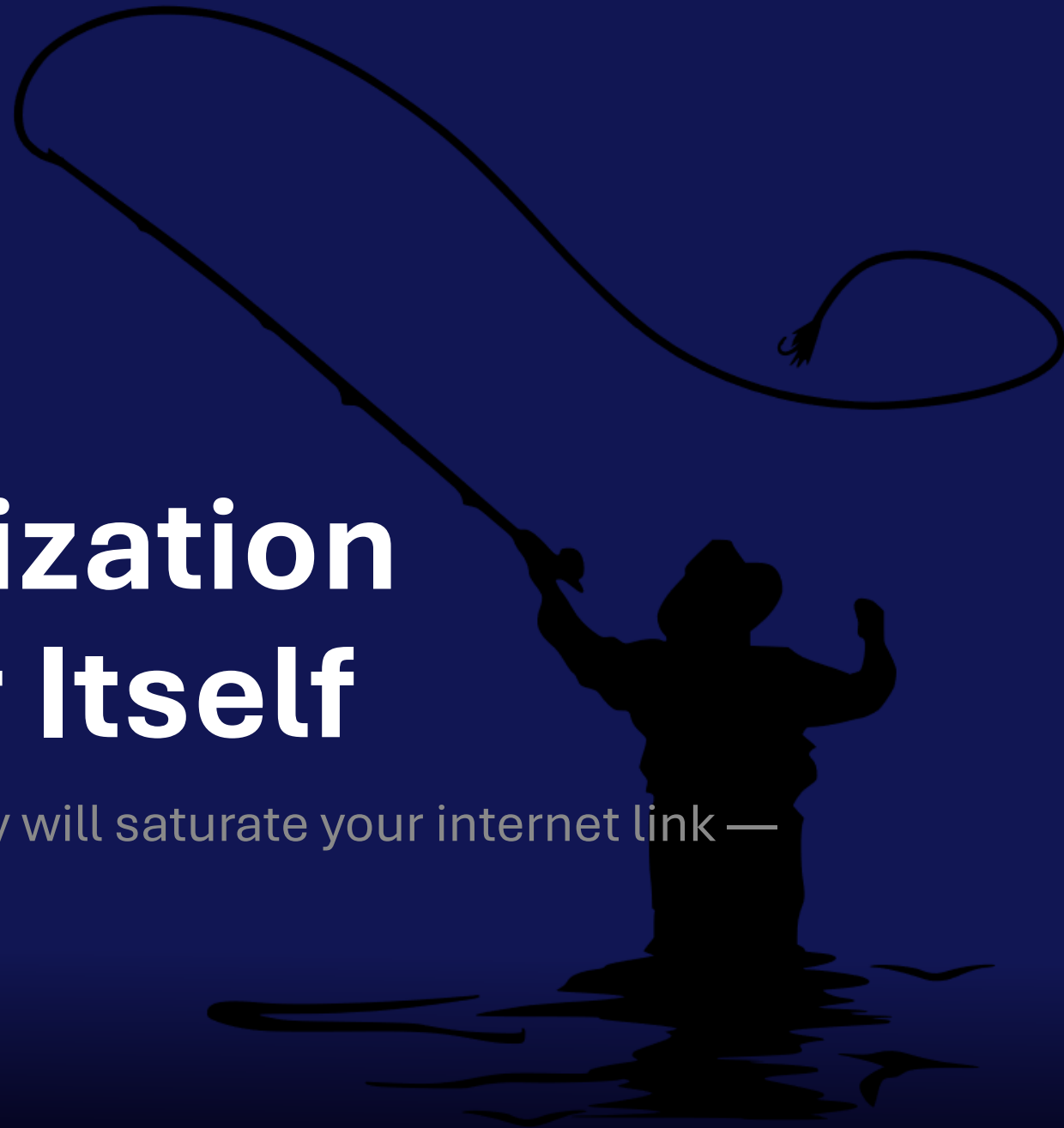
- ✗ Flipping workloads before Intune policies are configured; devices fall into a policy gap
- ✗ Moving all workloads at once instead of staging by risk
- ✗ Moving Client Apps first; it's the most complex workload and should go last
- ✗ Skipping pilot groups, cutting over all production devices without validation
- ✗ Using Pilot for workloads but adding a Collection that holds all devices.

✓ Do It Right

- ✓ Start with Compliance Policies: low risk, read-only, safe to validate in Intune first
- ✓ Use the "Pilot Intune" slider for Device Config: test on a ring before full cutover
- ✓ Build your Intune app catalog before moving the Client Apps workload
- ✓ Move workloads one at a time: validate each before proceeding to the next

Delivery Optimization Doesn't Deliver Itself

Leave it unconfigured and Patch Tuesday will saturate your internet link — every single month.



Assuming Delivery Optimization just works



How It Works

- Windows' built-in peer-to-peer caching engine
- Covers Windows Updates, Feature Updates, M365 Apps and Win32 Apps from Intune
- Devices share content with each other to cut internet egress
- Default mode (1 = LAN) only peers within the same subnet

✗ The Mistake

- ✗ Leaving DO at default — modern VLAN/microsegmented networks never peer
- ✗ Every device pulls from the CDN every Patch Tuesday
- ✗ 500 devices × 1 GB Quality Update = 500 GB egress, every month
- ✗ No bandwidth limits — updates saturate the link during business hours

✓ Do It Right

- ✓ Set Download Mode to 2 (Group) with a Group ID mapped to Entra group or subnet
- ✓ Cap background bandwidth: e.g. 25% in business hours, 80% off-hours
- ✓ Large estate? Deploy Connected Cache (on-prem or Azure) and prefer it
- ✓ Track peer vs CDN ratio in Intune → Reports → Delivery Optimization

💡 DO is on by default — but the default config is the one that costs you the most bandwidth.



Your Intune Admin Can Nuke the Fleet

Least privilege isn't just for end users. Your admin roles need scoping, PIM, and a hard look in the mirror.



Least Privileged Access



How It Works

- Intune Administrator (Entra role) can push scripts, deploy apps, wipe devices, and read BitLocker keys across the entire fleet
- Intune has its own RBAC: Help Desk Operator, Policy Manager, App Manager, Read Only Operator, and more
- Scope Tags further limit what a role can see. A regional admin sees only their region's devices

✗ The Mistake

- ✗ Assigning standing Intune Administrator (Entra) roles to day-to-day operators; no PIM, no expiry
- ✗ Using Entra roles instead of Intune RBAC; giving far more blast radius than needed
- ✗ Ignoring Scope Tags; one role sees and manages every device in every region
- ✗ Never auditing who holds the Intune Administrator role or eligible PIM assignments

✓ Do It Right

- ✓ Use Intune RBAC roles (not Entra roles) for all day-to-day operations
- ✓ Use also PIM for Intune RBAC roles
- ✓ Apply Scope Tags so each role sees only the devices it needs to manage
- ✓ Enforce PIM on all Intune Administrator (Entra) assignments; just-in-time, with MFA and optionally approval
- ✓ Audit quarterly: Entra ID > Roles > Intune Administrator, remove all standing access

💡 *Intune Administrator is a highly privileged Entra role — treat it like Global Admin and protect it with PIM.*

Privileged Access Groups in Intune RBAC

1

Create role-assignable group

Entra ID → New group → Azure AD roles can be assigned = Yes

2

Enable Privileged Access (PIM)

Group → Privileged Access → Enable → configure settings

3

Assign group to Intune RBAC role

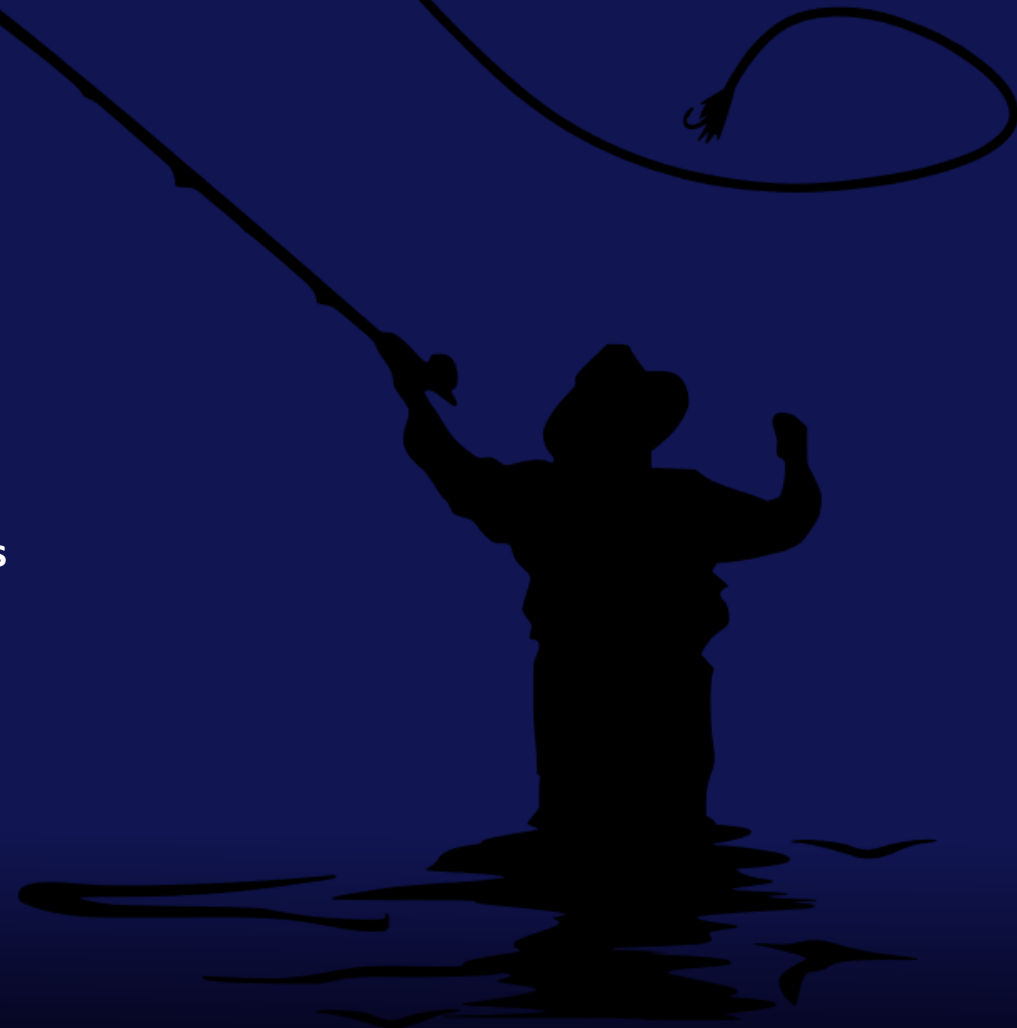
Intune → Tenant admin → Roles → custom role → Assignments

4

Add eligible members

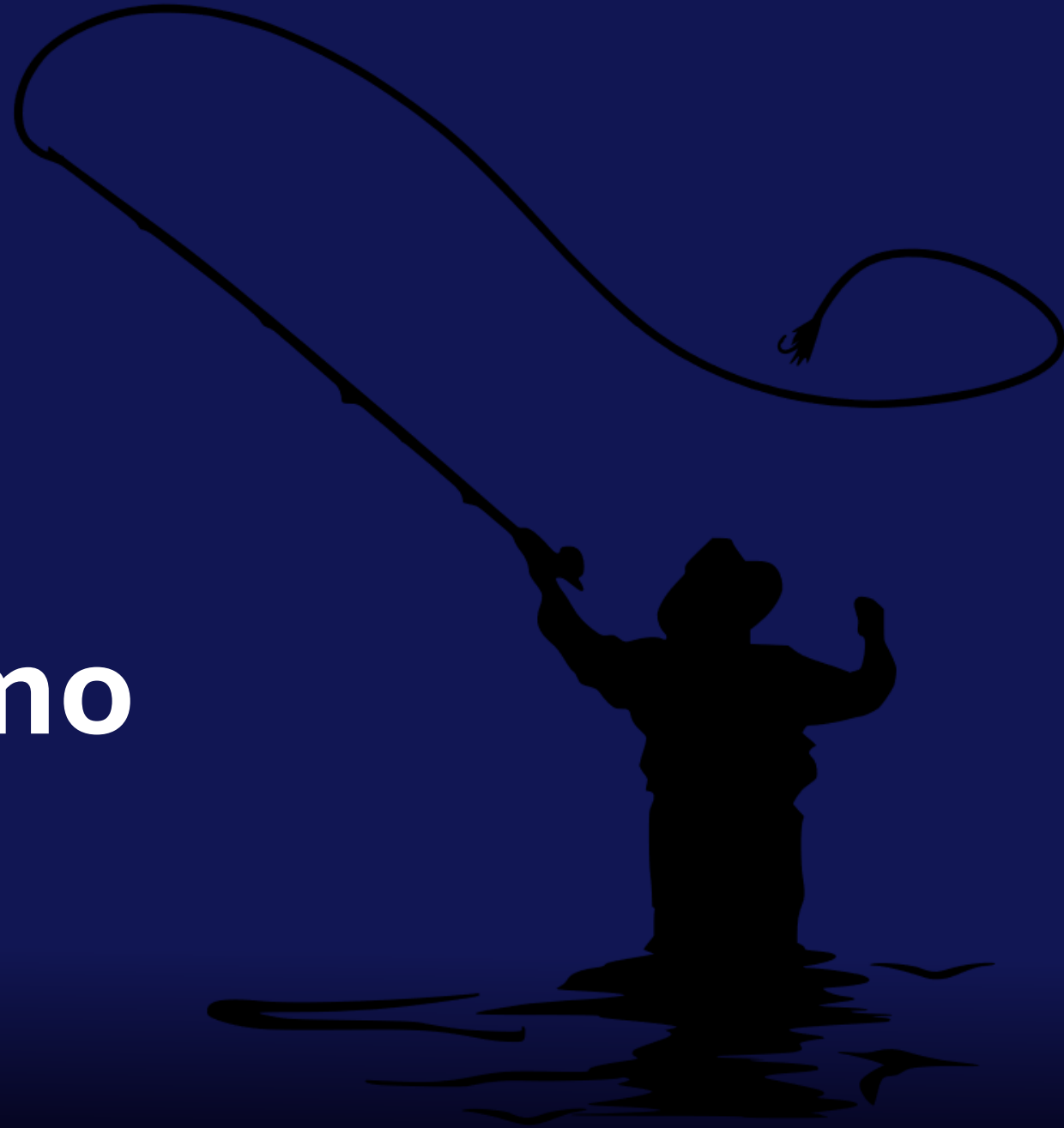
Entra PIM → group → Assignments → Eligible → select admins

⚠ Requires Entra ID P2 or Microsoft Entra ID Governance license



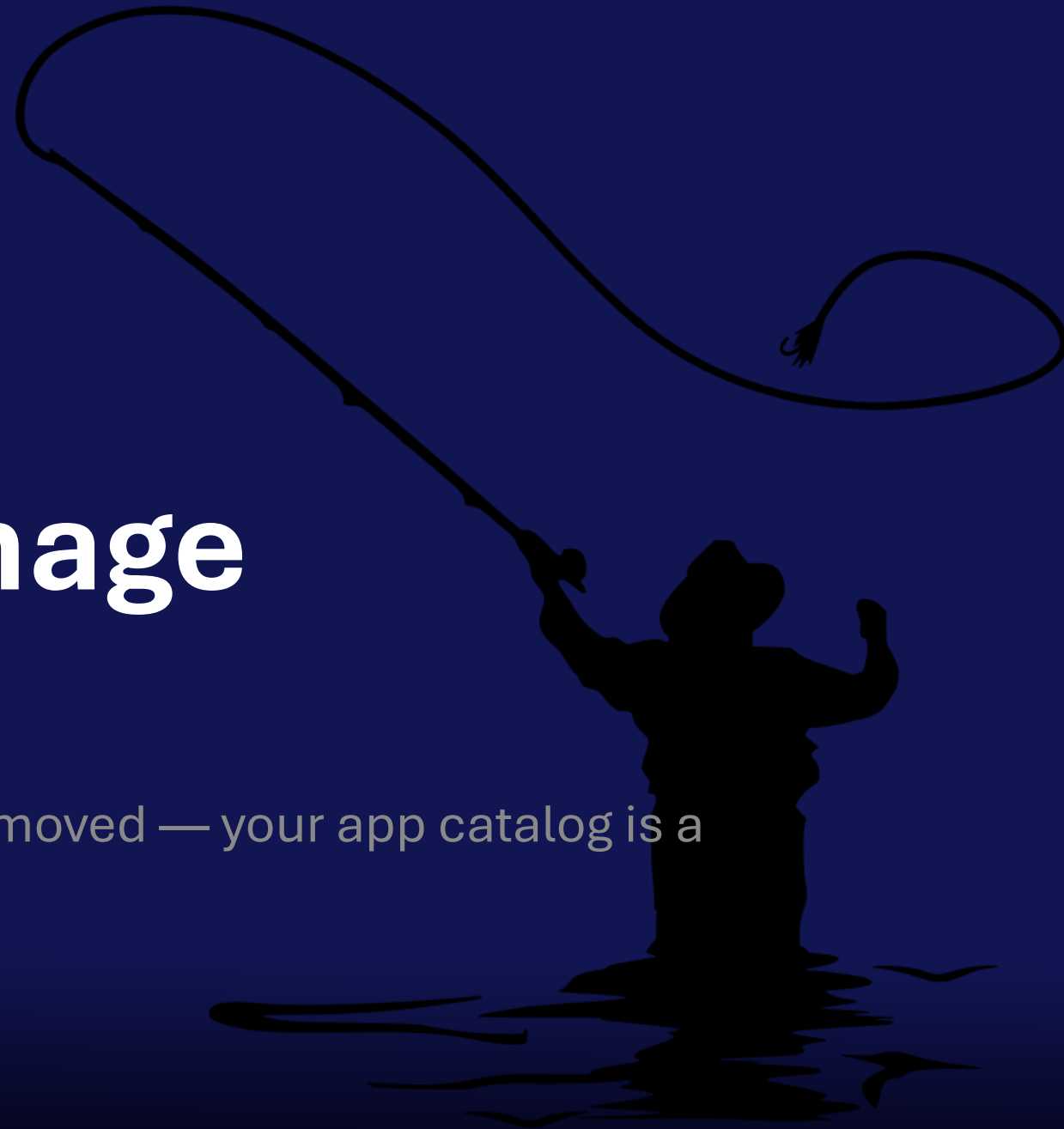
DEMO

PIM demo



Apps Don't Manage Themselves

Deployed once, never updated, never removed — your app catalog is a vulnerability catalog.



Ignoring application lifecycle management



How It Works

- Deploy: Win32 (.intunewin) gives full lifecycle control — install, uninstall, detection, return codes
- Update: third-party patching (Patch My PC, Robopack, Etc) keeps versions current
- Retire: remove all assignments first, then delete the app from Intune
- Track via Intune → Reports → Apps → App Install Status

✗ The Mistake

- ✗ Deploy once and forget — 1,000 devices on a year-old Chrome is a vulnerability factory
- ✗ Manual re-packaging every release — doesn't scale, slips behind
- ✗ Orphaned apps still assigned to groups that no longer exist
- ✗ No visibility into install failure rates on critical apps

✓ Do It Right

- ✓ Pick a patching tool from day one — don't leave third-party updates manual
- ✓ Quarterly app review: anything 2+ releases behind needs an update plan
- ✓ Retire anything with zero installs in 90 days
- ✓ Alert on high install-failure rates for business-critical apps

💡 An app deployed once and never updated isn't managed — it's a static attack surface waiting for a CVE.

Open for Business — Unintentionally

Without enrollment restrictions, your Intune tenant will happily accept any device anyone throws at it.



Enrollment restrictions not configured



How It Works

- Intune defaults to allowing any device, any OS, any version, any ownership
- Two control points: Device Type Restrictions + Device Limit Restrictions
- MDM enrollment = full device management; MAM = app-level only (BYOD)
- Restrictions can target groups — different rules for staff vs. contractors

✗ The Mistake

- ✗ Default open tenant — personal phones, old Macs, unvetted BYOD all enroll
- ✗ MDM-enrolling personal devices instead of using App Protection (MAM)
- ✗ macOS devices showing as “managed” with zero policies actually applied
- ✗ Editing the default catch-all policy instead of group-targeted restrictions

✓ Do It Right

- ✓ Block personally-owned iOS/Android in Device Type Restrictions — use MAM for BYOD
- ✓ Set minimum OS versions per platform; raise them as old releases go EOL
- ✓ Pre-assign compliance + config policies to all macOS groups before enrollment
- ✓ Assign restrictions to groups, not the catch-all default

💡 An open enrollment tenant isn't flexibility — it's an inventory you don't control. Decide who and what gets in before they show up.



Ghost Devices Are Haunting Your Tenant

Devices that left the building still living in Intune, Autopilot, and Entra ID — cleaning up is not optional.

Not Offboarding Your Devices Properly



How It Works

- A departed device still in Intune, Autopilot, and Entra ID skews compliance reports
- Three places to clean up: Intune (Retire + Delete), Autopilot (remove hash), Entra ID (delete object)
- Autopilot hash left behind = device can be re-enrolled to your tenant by anyone who holds it

✗ The Mistake

- ✗ Only retiring in Intune — leaving the Autopilot hash and Entra object untouched
- ✗ Deleting the Intune object without retiring first — management artifacts linger on the device
- ✗ No stale-device process — ghost objects accumulate for months, inflating license counts and compliance scores
- ✗ Stale Entra device objects appearing compliant in Conditional Access evaluations

✓ Do It Right

- ✓ Retire first in Intune (triggers selective wipe), then Delete — in that order
- ✓ Remove the Autopilot hash — prevents re-enrollment by an unauthorized party
- ✓ Delete the Entra ID object to free licenses and remove it from Conditional Access scope
- ✓ Run a monthly stale-device sweep (last check-in > 90 days) using DeviceOffboardingManager

💡 One Intune delete is not enough — all three systems must be cleaned up or the device can haunt you.

Device Offboarding: Best Practices & Tools

The 3-Step Sequence

- 1 Intune: Retire → Delete**
Retire sends selective wipe on next check-in.
Delete removes the MDM record. Order matters.
- 2 Autopilot: Delete device hash**
Devices > Enrollment > Windows Autopilot > Devices. Find and delete. Without this, the hardware can re-enroll.
- 3 Entra ID: Delete device object**
Entra ID > Devices > All devices. Frees the license slot and removes the device from CA scope.

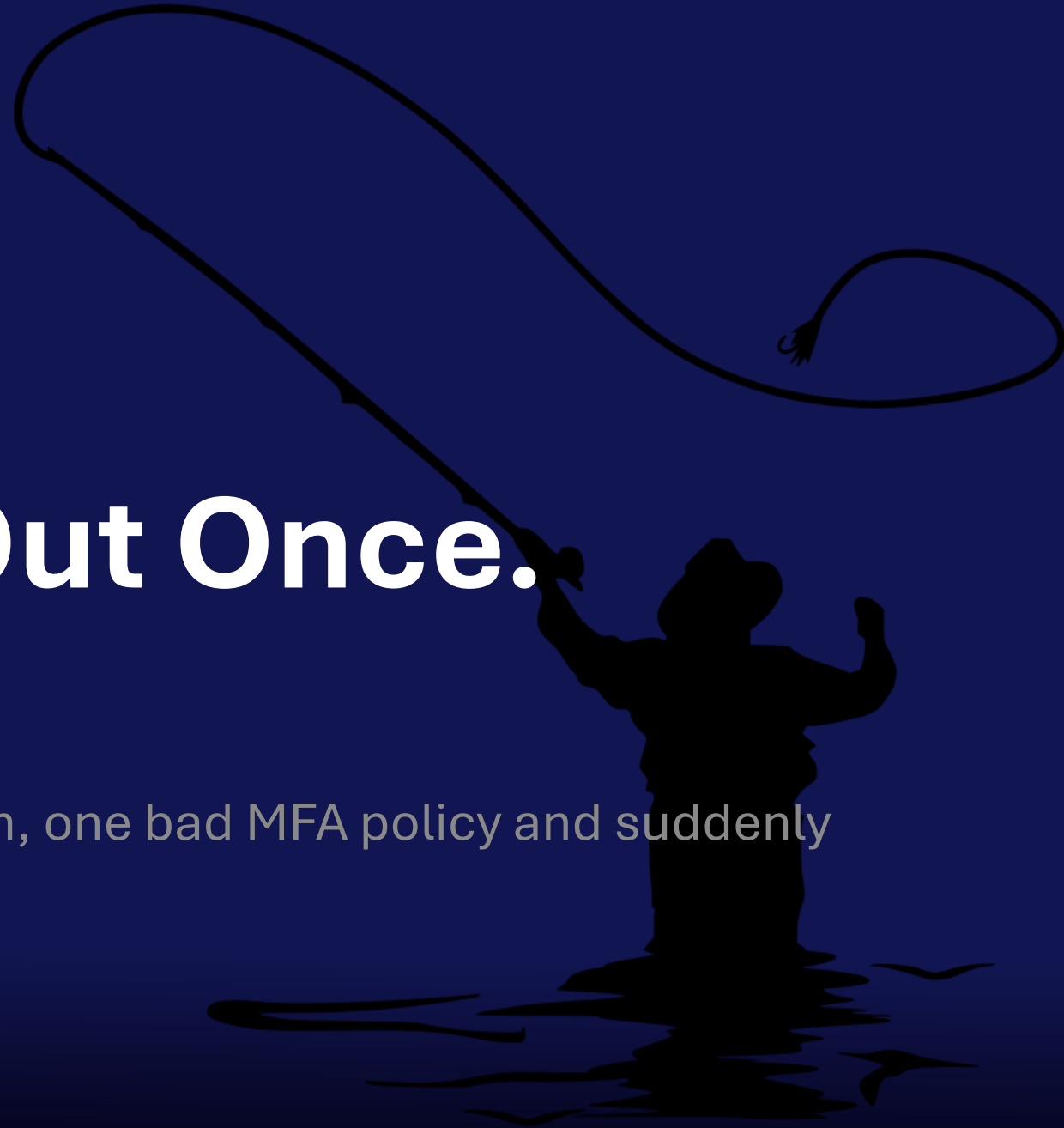
Community Tools

- DeviceOffboardingManager**
github.com/ugurkocde/DeviceOffboardingManager
PowerShell 7 GUI — bulk offboard from Intune, Autopilot & Entra ID. Stale device tracking (30/90/180d), real-time dashboard. By Ugur Koc.

 One Intune delete is not enough — all three systems must be cleaned up or the device can haunt you.

Lock Yourself Out Once. Learn Forever.

No break-glass account, no CA exclusion, one bad MFA policy and suddenly nobody can access the tenant.



Don't Lock Yourself Out (Break the Glass)



How It Works

- A break-glass account is a cloud-only, permanently Global Admin account used when normal admin access fails: MFA outage, IdP down, all admins locked out
- Two accounts, .onmicrosoft.com UPN, not federated or synced from on-prem
- Must be excluded from ALL Conditional Access policies: including MFA and device compliance
- Alert on any sign-in via Sentinel or Defender XDR: any use outside a declared emergency is a potential incident

✗ The Mistake

- ✗ No break-glass account at all: one MFA outage or federated IdP failure locks out every admin
- ✗ Break-glass account covered by a CA MFA policy: unusable in the exact emergency it was created for
- ✗ Credential stored only digitally or known by one person: single point of failure
- ✗ Never tested: account exists on paper but nobody knows if it actually works

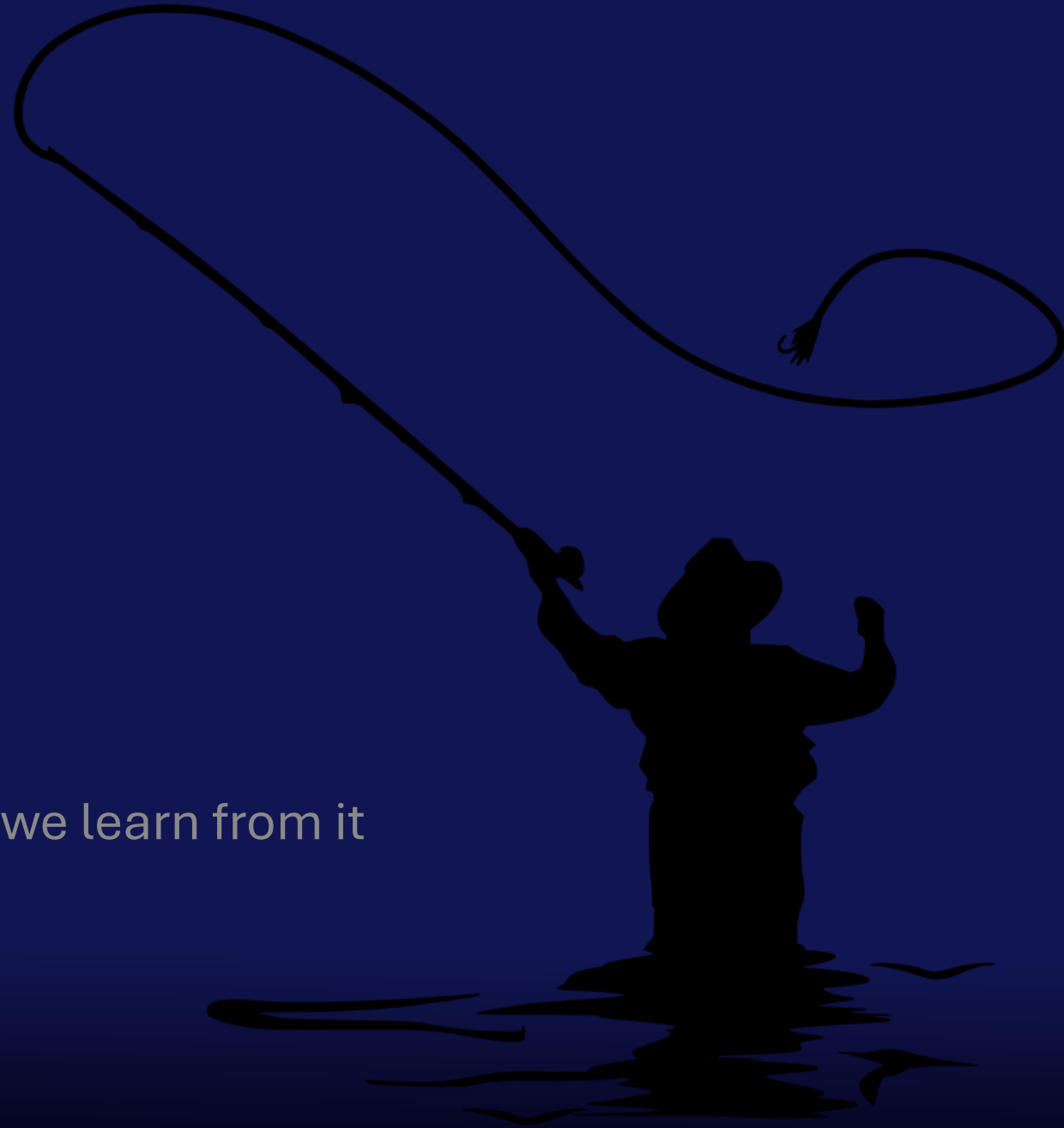
✓ Do It Right

- ✓ Two cloud-only accounts, .onmicrosoft.com UPN, standing Global Admin; no PIM on these
- ✓ Explicitly exclude both accounts from every Conditional Access policy
- ✓ Store credentials offline in a physical safe; split between two people, never digitally only
- ✓ Test quarterly + alert on every sign-in via Sentinel or Defender XDR

💡 *An untested break-glass account is as dangerous as no break-glass account — verify it works every quarter.*

Wrapping up ...

Everybody makes mistakes ... as long as we learn from it



Fishing Sessions

Be sure to find Wally and sign up for 1:1 time with a speaker
If you'd like to "catch" us for a session, we are scheduled as follows:

◆ Today:

- ◆ 3:00 PM
- ◆ 3:20 PM
- ◆ 3:40 PM

◆ Thursday:

- ◆ 8:00 AM
- ◆ 8:20 AM
- ◆ 8:40 AM
- ◆ 9:00 AM
- ◆ 9:20 AM



Don't forget to leave feedback for your speakers!

SAVE THE DATES

Oct 25-28, 2026



May 2-6, 2027



Oct 10-13, 2027



Extended Q&A



Recast

